

Circular S-03 — Third-Party Cyber Risk — Mandatory Assessment and Monitoring Framework

Reference:	FRA/S/2025/003	Issue Date:	20 Mar 2025
Effective Date:	01 Aug 2025	Response Deadline:	30 Jun 2025
Issuing Authority:	Financial Regulatory Authority	Classification:	MANDATORY

1. Scope

All critical technology vendors, cloud providers and fintech partners must be subject to an annual cybersecurity assessment. Assessments must be conducted by qualified assessors using the NIST Cybersecurity Framework or ISO 27001 as the baseline.

2. Minimum Standards

Vendors must demonstrate: MFA on all systems accessing firm data; encryption at rest and in transit; vulnerability management with critical patches within 72 hours; incident notification to the firm within 1 hour of any breach affecting firm data; annual penetration testing by an accredited third party.

3. Contractual Requirements

All new and renewing vendor contracts must include mandatory cybersecurity clauses specifying assessment rights, incident notification obligations and the right to terminate for persistent security failures. Firms must audit vendor compliance with contractual security requirements at least annually.

4. Reporting

Submit a Third-Party Cyber Risk Register to the Authority by 30 Jun 2025 listing all critical vendors, their last assessment date and any outstanding remediation items.